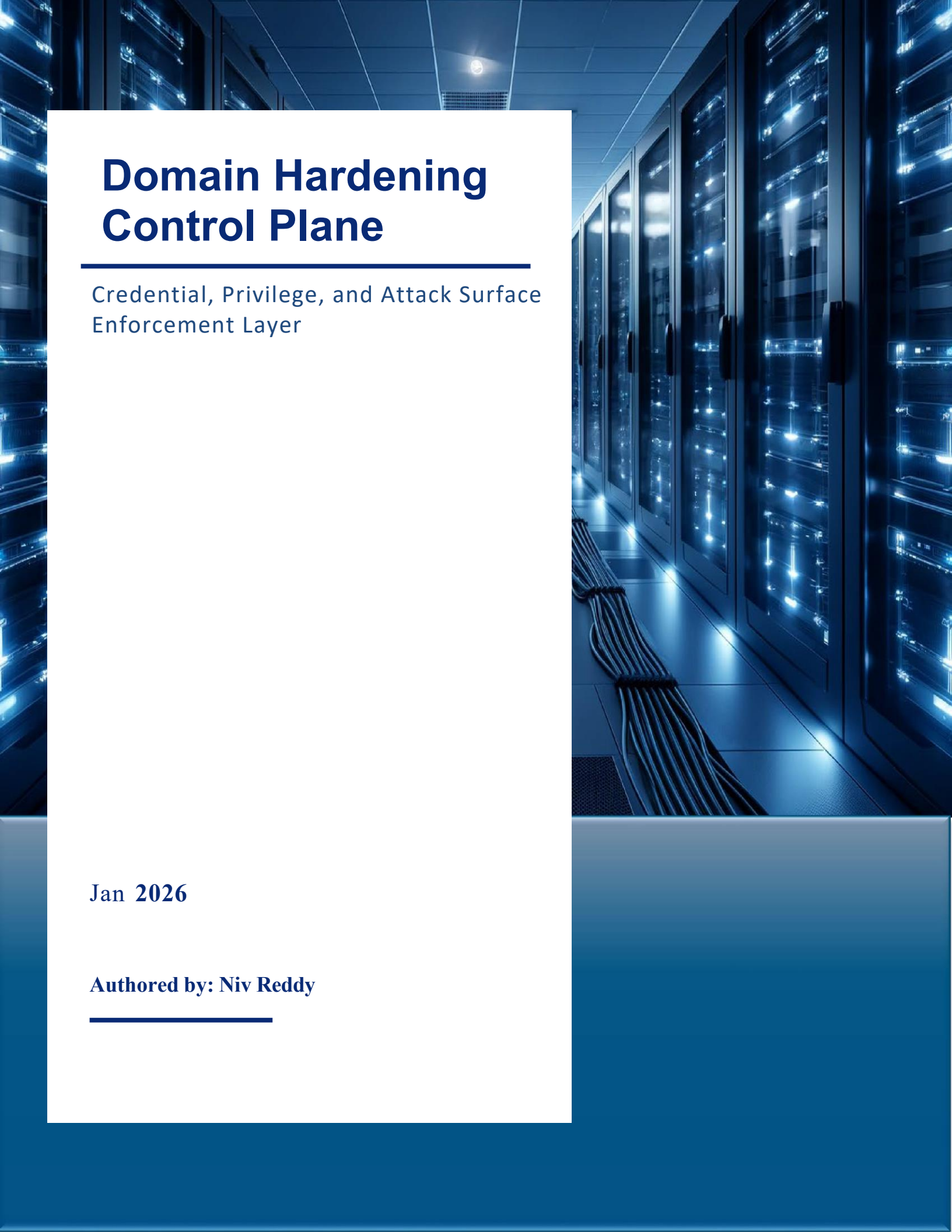




Domain Hardening Control Plane

Credential, Privilege, and Attack Surface
Enforcement Layer

Jan 2026

Authored by: Niv Reddy

Introduction

Context

This document defines the hardening and identity defense control plane for the lab.niv.local enterprise environment.

Earlier phases established the identity root (AD forest), enforced VLAN trust zones, and activated routed trust rails through a central broker (FW01). This phase hardens the authentication and privilege layers inside the trust fabric, transforming the domain from “working Active Directory” into a cryptographically enforced and operationally defensible identity platform.

This phase formally reduces credential theft surface area, eliminates relay and downgrade paths, enforces tier-based privilege separation, and implements post-compromise containment so that a Tier-2 workstation compromise cannot escalate into Tier-1 or Tier-0 control.

This phase establishes the defensive baseline required before monitoring and adversary simulation can be trusted as realistic

Objectives

- Cryptographic enforcement of authentication
- Removal of legacy authentication behaviors used for replay and downgrade
- Tier-based privilege isolation aligned with trust zones
- Controlled administrative pathways using PAW
- Local administrator governance and post-compromise containment
- Verifiable validation tests and enforcement confirmation

Domain Defense Control Plane Summary

Identity Defense Model

Tier	Role	Allowed Administrative Scope
Tier 0	Forest and domain control	DC and PAW only
Tier 1	Server administration	Members servers only
Tier 2	Endpoint administration	Workstations only

Credential Theft Surface Reduction

Purpose

Eliminate legacy authentication behaviors that enable credential replay and relay, including NTLM relay, SMB relay, and Kerberos downgrade. Authentication becomes cryptographically enforced and observable.

Threats Addressed

Attack Technique	Primary Control
Pass-the-Hash	NTLM restriction and auditing
NTLM Relay	LDAP signing and channel binding
Kerberos Downgrade	AES-only Kerberos enforcement
SMB Relay	SMB Signing (client + server)
Legacy hash theft	Disable LM hash storage

Controls Implemented

Authentication Hardening

- Kerberos restricted to AES-128/AES-256 only; RC4/DES disabled
- NTLM constrained to NTLMv2 only with domain-wide auditing
- LM hash storage disabled

Relay and Integrity Protection

- SMB signing mandatory for client and server
- LDAP signing required with channel binding
- Legacy authentication paths removed

Tier Boundary Enforcement

Purpose

Prevent domain takeover by enforcing that privileged credentials only exist and operate within the correct tier boundary.

Threats Addressed

Scenario	Primary Control
Domain Admin used on workstation	Tier restricted logon
Workstation used as admin jump box	PAW enclave + network restriction
Credential bleed across tiers	OU-scoped GPO boundaries
Workstation-to-server pivot	Identity and firewall alignment

Controls Implemented

Privileged Access Enclave

- PAW-01 deployed in VLAN30 Security Zone
- Tier-0 administration limited to PAW and DCs
- Workstations prohibited from reaching PAW

Tier-Restricted Logon

- T0 GPO: Tier-0 allowed only on DC/PAW and Tier-1/Tier-2 denied
- T1 GPO: Tier-1 allowed on servers; Tier-2 denied
- T2 GPO: Standard/Tier-2 allowed on workstations; Tier-0/Tier-1 denied

Network Alignment

- VLAN20 → VLAN30 blocked
- VLAN20 → VLAN10 limited to identity ports
- PAW → VLAN10 permitted for admin protocols

Post-Compromise Containment & Local Admin Governance

Purpose

Enforce tier-aligned local admin membership and interactive access control so that a compromised Tier-2 workstation cannot administer Tier-1 servers or Tier-0 systems.

Transition from Prior State

The risk of shared local administrator credentials was eliminated in Checkpoint 4.4 through tier-aligned Restricted Groups, RDP authorization, and network path controls. Local administration is now governed by domain identity tiers rather than machine-specific accounts.

Controls Implemented

Server Local Admin Governance

- GPO T1-SERVER-LOCAL-ADMIN enforces Administrators group =
 - LAB\T1-Server-Admins
 - LAB\T0-Domain-Admins
- Domain Admins removed from routine server administration

RDP Authorization

- Allow RDP: Tier-1 and Tier-0 only
- Deny RDP: Tier-2 identities

Tier Alignment

- T1 servers allow local logon only for Tier-1/Tier-0
- Workstations allow only Tier-2
- pfSense restricts admin paths to PAW enclave